

module2d1

1. Core Security Terms

Term	Simple meaning	Example
Asset	Something valuable that must be protected	Company database
Vulnerability	A weakness	Unpatched Windows server
Threat	Something that can cause harm	Hacker, malware
Exploit	Method/tool used to take advantage of a vulnerability	Exploit for an unpatched server
Risk	Chance that a threat will exploit a vulnerability and cause damage	Hacker exploiting weak password
Mitigation	Action taken to reduce the risk	Enable MFA and patch the server

example

Weak password → Vulnerability

Hacker → Threat

Brute-force attack → Exploit/attack method

Account compromise → Impact

MFA → Mitigation

Think:

Threat + Vulnerability + impact = Risk





2. Attack Vector

An **attack vector** is the **way an attacker gets to the target**.

Examples:

- Phishing email
- Weak password
- USB drive
- Vulnerable website
- Open network port
- Social engineering

Example

A hacker sends a fake Microsoft 365 login email.

Email → Victim → Fake website → Password stolen

The phishing email is the **attack vector**.



3. Threat Actors

White Hat 

Authorized ethical hacker.

Example: A company hires you to test its website.

Black Hat

Malicious hacker.

Example: Hacker steals customer credit cards.

Gray Hat

Finds vulnerabilities without proper authorization, often without clearly malicious intent.

Script Kiddie

Uses existing hacking tools without deeply understanding how they work.

Hacktivist

Attacks for political or social causes.

State-Sponsored Actor

Highly funded/organized attacker supported by a government.

Example: Stuxnet is a famous example of sophisticated state-linked cyber activity.

Remember



White = authorized

Black = malicious

Gray = unauthorized/unclear intent



4. Important Security Tools

Tool	Main purpose
Nmap	Network/port scanning
Wireshark	Capture and analyze packets
Tcpdump	Command-line packet capture
John the Ripper	Password cracking
Hydra	Online login/password attacks
Aircrack-ng	Wireless security testing
Metasploit	Exploitation/security testing
Kali Linux	Security testing operating system

Easy memory

Nmap → Find ports

Wireshark → See packets

John → Crack passwords

Metasploit → Exploit vulnerabilities

These tools are **dual-use**: defenders and attackers can use them.

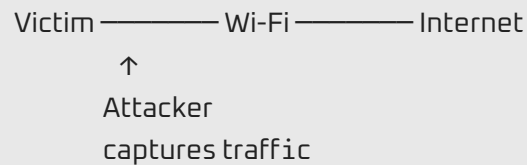


5. Common Network Attacks

Eavesdropping / Sniffing

Attacker captures network traffic.

Example:



Copy

Encryption such as HTTPS helps protect the data.



IP Spoofing

Attacker **forges the source IP address**.

Example:

Real attacker: 10.0.0.50
Fake source IP: 10.0.0.1

Copy

The packet appears to come from another device.



DoS

Denial of Service

One attacker overwhelms a target.

Attacker
↓↓↓↓↓
Server

Copy

Result:



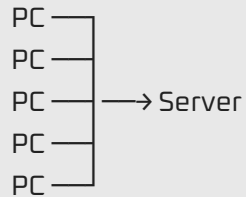
Legitimate users cannot access the service.



DDoS

Distributed Denial of Service

Many compromised devices attack one target.



Copy

Difference

DoS = one/few sources

DDoS = many distributed sources



6. Man-in-the-Middle (MitM)

An attacker places themselves between two communicating parties.

Alice ↔ Attacker ↔ Bob

Copy

The attacker may **read or modify communication**.

Example

You connect to a malicious/compromised Wi-Fi network, and the attacker intercepts traffic.



7. Malware

Virus

Usually requires some form of **user action/host execution** to spread.

Example:



You open an infected document → malicious code executes.



Worm

A worm can **self-replicate and spread automatically** across networks.

Important difference

Virus → usually needs user/host action

Worm → automatically spreads





Trojan

Malware disguised as legitimate software.

Example:



"Free Antivirus.exe" actually installs malware.



Ransomware

Encrypts files and demands payment.

Documents



Encrypted 🗝



"Pay money to decrypt"

Copy



Rootkit

Designed to **hide malicious activity** and maintain privileged access.



Spyware

Secretly monitors the victim.

Example:



Records browsing activity or sensitive information.



Keylogger

Records keystrokes.

Example:

User types:

Username: abraham

Password: *****

Keylogger → captures keystrokes

 Copy





8. Reconnaissance

Reconnaissance means **collecting information before an attack**.

Typical progression:

Information Gathering



Ping Sweep



Port Scan



Vulnerability Scan



Exploitation

Copy

Example

A tester wants to assess a server:

1. Find its IP address
2. Find whether it is online
3. Find open ports
4. Identify vulnerabilities
5. Test the vulnerability

Important



Recon = Learn about the target before attacking/testing it.



9. Password Attacks

Brute Force

Tries many possible passwords.

```
123456  
password  
admin123  
qwerty  
...
```

Copy

Dictionary Attack

Uses a list of commonly used passwords.

Defense

- Strong passwords
- MFA
- Account lockout/rate limiting

- Password managers



10. Social Engineering

Instead of attacking the computer, the attacker **manipulates the person**.

Phishing

Fake email/message designed to steal information.

Example:



"Your bank account will be closed. Click here immediately."

Spear Phishing

Targeted phishing against a specific person.

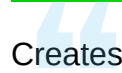
Baiting

Uses something attractive to trick the victim.

Example:

"Free USB — salary information inside."

Pretexting



Creates a fake story/identity.

Example:



Attacker pretends to be IT support and asks for your password.

Tailgating

Following an authorized person into a restricted area.

Shoulder Surfing

Watching someone enter their password.

Dumpster Diving

Searching discarded documents for useful information.

Key idea

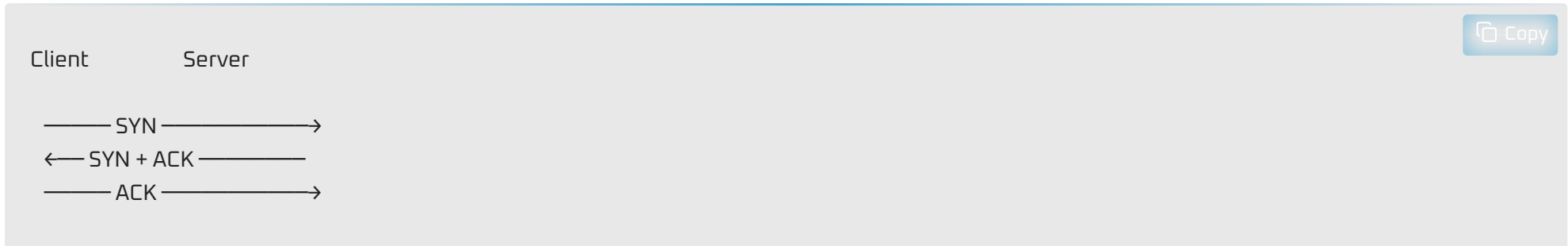


Social engineering attacks the human, not primarily the technology.



11. TCP Three-Way Handshake ☆

Very important for exams.



Meaning

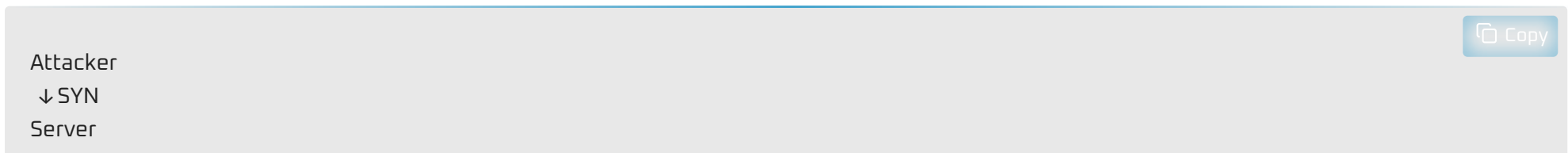
1. **SYN** → "Can we communicate?"
2. **SYN-ACK** → "Yes."
3. **ACK** → "Okay."

Connection established.



12. SYN Flood

Attacker sends many SYN requests but doesn't complete the handshake.



↓ SYN-ACK

× No ACK

The server keeps many connections **half-open**, consuming resources.

Defense examples

- SYN cookies
- Rate limiting
- Firewall/IPS filtering



13. TCP RST Attack

RST = Reset

A forged RST packet can force a TCP connection to terminate.

Think:



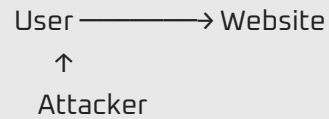
RST = "Stop this connection now."



14. TCP Session Hijacking

Attacker takes over an existing authenticated session.

Example:



Copy

If the attacker successfully obtains/uses the session information, they may act as the victim.



15. UDP

UDP is:

- Connectionless
- Low overhead
- No built-in retransmission
- No built-in flow control

Common uses:

- DNS
- VoIP
- Streaming
- TFTP

TCP vs UDP

TCP	UDP
Connection-oriented	Connectionless
Reliable	No delivery guarantee
More overhead	Less overhead
Handshake	No handshake
HTTP/HTTPS, SSH	DNS, VoIP, streaming



16. ARP Poisoning ☆

ARP maps:



IP address → MAC address

Example:

Gateway IP: 192.168.1.1
Gateway MAC: AA:AA:AA

 Copy

An attacker sends a fake ARP message saying:

192.168.1.1 = Attacker's MAC

Copy

Victim believes it.

Result:

Victim → Attacker → Gateway

Copy

This can enable a **MitM attack**.

Defense

Dynamic ARP Inspection (DAI) is an important switch-based defense.



17. DNS Attacks

DNS translates:

google.com → IP address

Copy

DNS Cache Poisoning

Attacker causes incorrect DNS information to be cached.

Example:

bank.com



Fake attacker website

Copy

DNS Tunneling

Uses DNS traffic to secretly transport data or commands.

Fast Flux

Rapidly changes IP addresses associated with malicious domains to make infrastructure harder to block.



18. DHCP ☆

DHCP automatically provides network configuration.

Remember:

DORA

D — Discover

O — Offer

R — Request

A — Acknowledgment

Client → Discover
Server → Offer
Client → Request
Server → ACK

Copy

DHCP can provide:

- IP address
- Subnet mask
- Default gateway
- DNS server



19. DHCP Spoofing

Attacker places a **rogue DHCP server** on the network.

The attacker's DHCP server may provide:

IP: Correct-looking
Gateway: Attacker
DNS: Attacker

Copy

Now traffic can potentially be intercepted or redirected.

Defense



DHCP Snooping

Switches can distinguish trusted and untrusted DHCP ports.



20. CIA Triad ☆☆☆

One of the **most important concepts in cybersecurity**.

C – Confidentiality

Only authorized people can access information.

Example: Encryption.



I – Integrity

Data hasn't been improperly changed.

Example: Hashing.



A – Availability

Systems/data are available when needed.

Example: Redundant servers and backups.

Easy example

A university database:

- **Confidentiality:** Students can't see other students' private information.
- **Integrity:** Grades cannot be secretly changed.
- **Availability:** Students can access the system during registration.



21. Defense in Depth

Use **multiple layers of security**.

Internet



Firewall



IPS



Authentication



Endpoint Security



Copy

Database

If one security layer fails, another can still protect the organization.



Defense in depth = don't depend on one security control.



22. Firewall vs IPS ☆

Firewall

Controls traffic based on rules.

Example:

Allow TCP 443
Block TCP 23

Copy

Main idea:



Firewall = controls access

IPS

Inspects traffic and can **actively block malicious activity**.

Main idea:



IPS = detects and prevents attacks



23. Cryptography Basics

Encryption

Makes readable data into unreadable ciphertext.

Hello
↓ encryption
X7@kP9#

Copy

Used mainly for **confidentiality**.



Hashing

Creates a fixed-length digest.

File
↓ SHA-256
Hash

Copy

Used mainly to check **integrity**.

Important difference

Encryption → can be decrypted with the proper key

Hashing → designed to be one-way



24. Hash Algorithms

Algorithm	Status
MD5	× Broken/legacy
SHA-1	× Legacy
SHA-256	□ Common modern choice
SHA-384	□
SHA-512	□

Important

A normal hash doesn't prove **who** created the data.

For authentication/integrity with a shared secret:



25. Secure Communication

Four important security properties:

Confidentiality

Prevent unauthorized reading.

Tool: Encryption

Integrity

Prevent/detect unauthorized modification.

Tool: Hash/HMAC

Authentication

Verify who you are communicating with.

Example: Digital certificates

Non-repudiation

Provide evidence that a party performed/signed an action.

Example: Digital signatures